

**Regulatory Requirements and Implementation Strategies
Under PCI-DSS**

Joseph Patnoe

University of Arizona

CYBV 442: Regulatory Limitations and Controls for Cyber Operations

Professor Calhoun-Lopez

23 January 2026

Table of Contents

Introduction.....	3
Requirements.....	3
Fulfillment.....	4
Conclusion.....	5
References	6

Introduction

PCI DSS is an industry security standard that operates as a de facto regulatory requirement for any organization that stores, processes, or transmits payment card data. It establishes a baseline of technical and operational cybersecurity controls intended to protect account data and standardize security expectations across the global payment ecosystem (PCI Security Standards Council, 2022). A foundational concept within PCI DSS is *scope*: the standard applies to the cardholder data environment (CDE), which includes the people, processes, and technologies that store, process, or transmit cardholder data, as well as any system components that could impact the security of that environment (PCI Security Standards Council, 2022). As a result, compliance begins with identifying where cardholder data resides, how it flows through the organization, and which systems are connected in ways that could affect the protection of that data (PCI Security Standards Council, 2022).

Requirements

PCI DSS imposes cybersecurity requirements across administrative, technical, and physical domains. The standard organizes these obligations into 12 principal requirements, including maintaining network security controls; removing vendor-supplied defaults; protecting stored cardholder data; encrypting data transmission over open networks; protecting systems from malware; developing and maintaining secure systems and applications; restricting access based on business need-to-know; assigning unique IDs and implementing strong authentication; restricting physical access; tracking and monitoring system access; regularly testing security systems and processes; and maintaining a comprehensive information security policy (PCI Security

Standards Council, 2022). These requirements do not function as abstract guidance; rather, they drive internal policy development and operational standards. As discussed in PCI DSS audit literature, organizations must translate these control objectives into documented procedures, role assignments, and measurable security practices that can be validated during assessment (Ataya, 2011).

Fulfillment

Organizations typically fulfill PCI DSS requirements through a structured compliance program that integrates governance, risk management, and technical implementation. A common approach begins with defining and, where possible, reducing the scope of the CDE, followed by conducting a gap analysis against the PCI DSS requirements and remediating identified deficiencies (Ataya, 2011). Mature organizations often align PCI DSS efforts with broader information security management frameworks and governance models to embed compliance into existing processes rather than treating it as a stand-alone project (Nicho et al., 2011). This layered implementation approach reflects the broader GRC principle that effective compliance requires coordinated administrative, technical, and physical controls working together, rather than reliance on a single security mechanism (University of Arizona, CYBV 442 Week 1 Lecture).

Outsourcing is permitted under PCI DSS and is commonly used to reduce scope or leverage specialized expertise; however, accountability cannot be transferred. The PCI Security Standards Council explicitly states that using a third-party service provider does not make an organization PCI DSS compliant and does not remove the organization's responsibility for ensuring compliance within its own environment (PCI

Security Standards Council, 2022). In practice, organizations may outsource payment processing, managed security services, or portions of the compliance validation process, but they must perform due diligence, clearly define shared responsibilities in contracts, and monitor the service provider's compliance status at least annually (PCI Security Standards Council, 2025). Thus, while operational tasks may be delegated, the ultimate obligation to ensure cardholder data protection remains with the merchant or service provider (Ataya, 2011).

Conclusion

Whether an organization must engage an external auditor depends on its merchant or service provider level and transaction volume. Some organizations validate compliance through self-assessment questionnaires, while others are required to undergo a formal assessment conducted by a Qualified Security Assessor (QSA), resulting in documented compliance reporting such as a Report on Compliance (PCI Security Standards Council, 2025; Ataya, 2011). Even when external certification is not mandated, organizations must maintain sufficient documentation and evidence to demonstrate that each applicable requirement is implemented and operating effectively. As emphasized in governance literature, compliance is not synonymous with security; organizations must ensure that PCI DSS controls are not only documented for audit purposes but are embedded into continuous operational practice to meaningfully reduce risk (University of Arizona, CYBV 442 Week 1 Lecture; Nicho et al., 2011).

References

Ataya, G. (2010). PCI DSS audit and compliance. *Information Security Technical Report*, 15(4), 138–144. <https://doi.org/10.1016/j.istr.2011.02.004>

Nicho, M., Fakhry, H., & Haiber, C. (2011). *An integrated security governance framework for effective PCI DSS implementation*. *International Journal of Information Security and Privacy*, 5(3), 50–67.

PCI Security Standards Council. (2025). *Report on Compliance (ROC) template for PCI DSS (Version 4.0.1)*. <https://www.pcisecuritystandards.org>

PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard: Requirements and testing procedures (Version 4.0)*. <https://www.pcisecuritystandards.org>

University of Arizona. (n.d.). *CYBV 442 week 1 lecture* [PowerPoint slides]. D2L Course Site.